

Agentic AI Safety Checklist

Before your AI agent can act, make sure it has the right limits.

Use this before letting an AI agent send messages, change records, or trigger workflows. This is a practical readiness review, not a substitute for full security governance. Anything unchecked is a risk to address.

Inventory & ownership

- ☐ Every agent has a named human owner.
- ☐ Its purpose and business process are documented.
- ☐ You have a list of every system and tool it can access.

Permissions (least privilege)

- ☐ The agent has only the access it actually needs.
- ☐ No standing admin or broad write access by default.
- ☐ Separate credentials for test and production.
- ☐ API keys / service accounts are scoped and revocable.

Human approval gates

- ☐ External messages (email/SMS) require human approval.
- ☐ Record changes (CRM, orders, bookings) require approval.
- ☐ Quotes, payments, and refunds require approval.
- ☐ Bulk or irreversible actions are blocked or gated.

Prompt injection & inputs

- ☐ Untrusted content (emails, web pages, documents) cannot issue commands.
- ☐ System instructions are separated from user/content input.
- ☐ Tool calls are validated before they execute.
- ☐ The agent ignores instructions embedded in data it reads.

Data exposure & privacy

- ☐ The agent cannot reach data outside its task.
- ☐ Sensitive and personal fields are masked or excluded.
- ☐ Outputs are checked for leaked or over-shared data.
- ☐ A data-handling agreement is in place where needed.

Logging, audit & rollback

- ☐ Every agent action is logged.
- ☐ Logs are retained and reviewable.
- ☐ Each action can be traced back to what triggered it.
- ☐ A rollback or undo process exists for changes.

Escalation & failure

- ☐ The agent escalates on low confidence or errors.
- ☐ There is a clear off-switch and kill criteria.
- ☐ The owner is alerted on anomalies or spikes.

Go / no-go

- ☐ High-impact actions are gated or disabled for launch.
- ☐ The owner has signed off before go-live.
- ☐ A re-review is scheduled after any change to tools or prompts.